DARSHANA OPTICALS

Optical Shop Management System (OSMS)

OWASP TOP 10
COMPLIANCE CHECKLIST

Final Security Verification Evidence

Document Version: 1.0

Verification Date: 25 October 2026

Deployment Environment: Render Backend and Vercel Frontend

DOCUMENT INFORMATION

Project	Darshana Opticals - Optical Shop Management System (OSMS)
Issue	DDP-085 - Security Verification
Primary Issue	darshana-opticals-osms/backend#91
Document Version	1.0
Verification Date	25 October 2026
Status	Final Security Verification Evidence
Backend Branch Verified	develop
Frontend Branch Verified	develop
Deployment Environment	Render backend and Vercel frontend
Backend URL	https://osms-backend-staging.onrender.com
Frontend URL	https://darshana-opticals.vercel.app

1. Purpose

This document provides the final OWASP Top 10 security verification checklist and supporting evidence for the Optical Shop Management System.

The assessment was performed under DDP-085 to verify the implemented application security controls before final release.

The verification focused on the existing implementation and applied only minimal targeted hardening where verified security gaps were identified.

This document does not contain passwords, JWT values, database credentials, payment-provider secrets, or real sensitive Customer information.

2. Assessment Scope

The security assessment covered the following OSMS areas:

- Authentication
- Password recovery
- Role-Based Access Control
- Customer ownership controls
- Branch-scoped access
- Clinical Prescription data
- Shopping Cart
- Checkout
- Payments
- Orders
- Appointments
- Doctor Sessions
- Inventory
- Reorder Alerts
- Loyalty

- Administrative operations
- Reporting
- AI Chatbot integration
- File and image upload
- Notifications
- Immutable audit trail
- Frontend security
- Backend security
- Dependency vulnerabilities
- Deployment configuration
- Security logging and monitoring

3. Final Verification Baseline

Backend

Final backend regression result:

- **118 / 118 test suites passed**
- **2075 / 2075 tests passed**
- ESLint passed
- Prettier passed
- `git diff --check` passed
- Backend CI run #501 passed

Latest backend verification:

- 118 / 118 test suites passed
- 2076 / 2076 tests passed
- Backend CI run #517 passed
- Dependency security gate: 0 Critical / 0 High

Final backend dependency result:

- **0 Critical**
- **0 High**
- **2 Moderate**

The remaining Moderate dependency findings are transitive findings associated with `exceljs -> uuid`.

The available forced automatic remediation was not applied because it would introduce a potentially breaking dependency change.

Frontend

Final frontend verification result:

- **110 / 110 test files passed**
- **1341 / 1341 tests passed**
- Statements coverage: **88.05%**
- Branch coverage: **81.80%**
- Functions coverage: **90.95%**
- Lines coverage: **88.86%**
- ESLint passed

- Prettier passed
- Production build passed

Final frontend dependency result:

- **0 Critical**
- **0 High**
- **2 Moderate React Router advisories**

The remaining Moderate advisories require a breaking major-version upgrade for automatic remediation and are recorded as residual dependency risk.

4. OWASP Top 10 Compliance Summary

OWASP Category	Verification Summary	Result
A01 - Broken Access Control	Authentication, RBAC, ownership, branch isolation, administrative and protected-resource access verified	**PASS**
A02 - Cryptographic Failures	Password hashing, token handling, HTTPS, HSTS and sensitive-data protection reviewed	**PASS**
A03 - Injection	Input validation, malformed requests and privileged-field injection protections verified	**PASS**
A04 - Insecure Design	Critical payment, inventory, appointment, clinical, loyalty and audit design boundaries reviewed	**PASS**
A05 - Security Misconfiguration	CORS, HTTPS, security headers, safe errors and deployed configuration verified	**PASS**
A06 - Vulnerable and Outdated Components	Backend and frontend dependency scans satisfy Critical/High release gate	**PASS**
A07 - Identification and Authentication Failures	Rate limiting, account lockout, recovery and deployed authentication verified	**PASS**
A08 - Software and Data Integrity Failures	CI, lockfile integrity, peer review, merge and deployment traceability verified	**PASS**
A09 - Security Logging and Monitoring Failures	Security events and privacy-safe authentication logging verified in deployed Render logs	**PASS**
A10 - Server-Side Request Forgery	External-request boundaries reviewed; no arbitrary server-side URL-fetch capability identified	**PASS**

5. A01 - Broken Access Control

Verification Performed

The assessment verified:

- requests without authentication;
- invalid JWT handling;
- protected administrative endpoints;
- unauthorized role access;

- Customer ownership boundaries;
- cross-customer access restrictions;
- branch-scoped access restrictions;
- clinical data access restrictions;
- inventory access controls;
- reporting authorization;
- administrative operation authorization;
- public attempts to inject privileged roles.

Backend authorization remains authoritative and does not rely solely on frontend route protection.

Deployed Evidence

The deployed Render backend confirmed:

- protected administrative access without authentication returns HTTP 401;
- invalid authentication tokens are rejected safely;
- public registration rejects attempts to create privileged roles;
- unexpected privileged `role` input is rejected;
- frontend authentication successfully operates through the protected backend APIs.

Result

PASS

6. A02 - Cryptographic Failures

Verification Performed

The assessment verified:

- passwords are stored using bcrypt-based hashing;
- plaintext passwords are not stored by application authentication logic;
- JWT signing secrets are environment-controlled rather than hard-coded;
- password-reset functionality uses protected reset-token handling;
- sensitive token values are not intentionally logged;
- deployed backend communication uses HTTPS;
- deployed frontend communication uses HTTPS;
- HSTS is enabled;
- authentication failures do not expose password hashes or credentials.

Deployed Evidence

Backend HSTS was verified with:

```
max-age=31536000; includeSubDomains
```

Frontend HSTS was verified with:

```
max-age=63072000; includeSubDomains; preload
```

Result

PASS

7. A03 - Injection

Verification Performed

Input-validation and security testing covered representative inputs across:

- authentication;
- registration;
- appointments;
- inventory;
- checkout;
- payments;
- prescriptions;
- reporting;
- administrative operations;
- chatbot inputs.

Deployed Evidence

The deployed backend confirmed:

- malformed JSON receives a controlled HTTP 400 response;
- unexpected privileged `role` fields during login are rejected;
- privileged role injection during public registration is rejected;
- invalid input does not expose internal stack traces.

Result

PASS

8. A04 - Insecure Design

The assessment reviewed security-sensitive business workflows and their existing design boundaries.

Verified Design Risks and Mitigations

Design Risk	Existing / Verified Mitigation
Duplicate or forged payment effects	Provider verification, amount/currency validation, replay/idempotency controls and reconciliation
Inventory overselling	Transaction-backed inventory reservation/restoration and concurrency controls
Appointment overbooking	Session-capacity and scheduling conflict controls
Cross-customer clinical disclosure	Backend role and ownership restrictions
Cross-branch access	Server-side RBAC and branch-scoped authorization
Unauthorized loyalty manipulation	Backend-authoritative loyalty calculations and persistence
Audit-history tampering	Immutable audit-trail architecture and restricted mutation paths
Authentication brute force	IP-based rate limiting and account-level temporary lockout
Unsafe arbitrary server requests	Provider destinations are controlled; no generic arbitrary URL-fetch feature identified
Sensitive information in logs	Sanitized and privacy-safe security logging

The verified A04 security-design and threat-risk findings are tracked under DDP-088 for incorporation into the final SDS.

Result

PASS – security assessment completed. The verified A04 design-risk findings are tracked for incorporation into the final SDS under DDP-088.

9. A05 - Security Misconfiguration

Verification Performed

The assessment reviewed:

- environment-controlled configuration;
- HTTPS;
- CORS;
- error handling;
- security headers;
- frontend production configuration;
- absence of debug authentication bypasses;
- production API configuration.

Backend Deployment Evidence

The Render backend returned:

- HTTPS;
- HSTS;
- Content Security Policy;
- `X-Content-Type-Options`;
- `X-Frame-Options`;
- Referrer Policy;
- Cross-Origin security headers.

An unauthorized origin such as:

```
https://attacker.example.com
```

did not receive an approved `Access-Control-Allow-Origin` response.

The approved production frontend origin:

```
https://darshana-opticals.vercel.app
```

was accepted.

Credentialed CORS support returned:

```
Access-Control-Allow-Credentials: true
```

Frontend Deployment Evidence

The production Vercel frontend returned:

- HTTP 200;
- HSTS;
- `X-Content-Type-Options: nosniff`;
- `X-Frame-Options: DENY`;
- `Referrer-Policy: no-referrer`;

- restrictive `Permissions-Policy`;
- Content Security Policy including:

- `frame-ancestors 'none'`;
- `object-src 'none'`;
- `base-uri 'self'`.

Result

PASS

10. A06 - Vulnerable and Outdated Components

Backend

Initial dependency scanning identified security findings requiring remediation.

After safe remediation and final verification:

- **0 Critical**
- **0 High**
- **2 Moderate**

The remaining Moderate findings are transitive through `exceljs -> uuid`.

No `npm audit fix --force` operation was used because the forced remediation would introduce a potentially breaking dependency change.

Frontend

Final frontend scanning reported:

- **0 Critical**
- **0 High**
- **2 Moderate React Router advisories**

The automatic remediation requires a breaking React Router major-version upgrade and was therefore not force-applied during DDP-085.

Result

PASS for the DDP-085 Critical/High vulnerability release gate

Residual Moderate dependency risks remain documented for future safe remediation.

11. A07 - Identification and Authentication Failures

Controls Verified

The assessment verified:

- authentication rate limiting;
- generic authentication-error responses;
- account-level failed-login tracking;
- temporary account lockout;
- concurrency-safe lockout behavior;
- post-lockout authentication recovery;
- inactive-account handling;

- JWT-based authentication.

Relevant backend security hardening included:

- initial account-lockout implementation;
- concurrency-safe lockout handling;
- zero-state stale-success race-condition remediation.

Final Automated Evidence

- **118 / 118 backend test suites passed**
- **2075 / 2075 backend tests passed**
- Backend CI run #501 passed

Deployed Account-Lockout Evidence

Using a fictional staging Customer account:

- five consecutive incorrect-password attempts returned HTTP 401;
- the correct password was rejected while the account remained locked;
- after the 15-minute lock expired, the correct credentials authenticated successfully;
- the authenticated identity returned the expected `CUSTOMER` role.

Credentials used during verification are intentionally excluded from this document.

Frontend Integration Evidence

The production frontend confirmed:

- login against the deployed Render backend;
- authenticated Customer functionality;
- authenticated state remaining valid after refresh;
- successful logout.

Result

PASS

12. A08 - Software and Data Integrity Failures

Verification Evidence

The security changes were subject to:

- source control;
- automated testing;
- GitHub Actions CI;
- dependency scanning;
- peer review;
- merge traceability;
- deployment verification.

Backend DDP-085 PR:

`darshana-opticals-osms/backend#108`

Title:

`[DDP-085] test(security): complete OWASP verification and backend security hardening`

Status:

Approved and merged

Merge commit:

`0881662c582c42768c010042a7a3d4be8bfd4d1f`

Frontend DDP-085 PR:

`darshana-opticals-osms/frontend#68`

Title:

`[DDP-085] fix(security): remediate frontend dependency vulnerabilities`

Status:

Merged

Frontend merge commit:

`a21e1a0ad420e3ea07be1896a38898d9e496dcf4`

The accepted backend security revision was deployed successfully to Render.

Result

PASS

13. A09 - Security Logging and Monitoring Failures

DDP-085 introduced and verified privacy-safe authentication and access-rejection security events.

Runtime Events Verified

The deployed Render logs confirmed:

- `[SecurityAuth] LOGIN_FAILED`
- `[SecurityAuth] LOGIN_BLOCKED_LOCKED`
- `[SecurityAccess] AUTHENTICATION_REJECTED`

The observed security log entries did not expose:

- passwords;
- JWT/access-token values;
- sensitive credentials;
- unnecessary Customer data.

The logs therefore provide security-event visibility without intentionally exposing authentication secrets.

Result

PASS

14. A10 - Server-Side Request Forgery

The assessment reviewed the system's external-service request boundaries.

External provider communication is performed through controlled application integrations rather than a generic user-controlled URL-fetch capability.

No feature was identified that permits an arbitrary user-supplied URL to be fetched by the backend server.

Relevant external integrations remain constrained to configured or application-controlled provider destinations.

Result

PASS

15. Frontend Security Verification

Frontend DDP-085 security remediation and verification included:

- dependency vulnerability scanning;
- production build verification;
- public Vite environment-variable review;
- browser-bundle secret checks;
- authentication/session handling;
- protected navigation;
- safe rendering behavior;
- password-reset handling;
- payment-state integrity;
- error presentation;
- production security headers;
- CORS integration with the deployed backend.

Final evidence:

- **110 / 110 test files passed**
- **1341 / 1341 tests passed**
- **88.05% statements**
- **81.80% branches**
- **90.95% functions**
- **88.86% lines**
- ESLint passed
- Prettier passed
- production build passed
- **0 Critical / 0 High dependency vulnerabilities**

The existing browser-side JWT `localStorage` architecture remains a documented residual design consideration and was not redesigned under DDP-085.

Result

PASS

16. Post-Deployment Security Verification

The planned frontend and backend DDP-085 post-deployment security verification has been completed.

Verified after deployment:

- backend `/api/health` returned HTTP 200;
- HTTPS verified;
- HSTS verified;
- backend security headers verified;
- frontend security headers verified;
- generic invalid-login response verified;
- account lockout verified;
- correct password rejected while locked;
- successful recovery after lock expiry verified;

- approved production Vercel CORS verified;
- credentialed CORS verified;
- frontend login verified;
- authenticated Customer functionality verified;
- authenticated refresh verified;
- logout verified;
- Render authentication-security logs verified;
- privacy-safe security logging verified.

Result

PASS

17. Residual Security Risks and Limitations

The following non-blocking residual risks are recorded:

Backend Dependencies

- 2 Moderate dependency findings remain through `exceljs -> uuid`.
- No Critical or High vulnerability remains.
- Forced remediation was avoided because it could introduce a breaking dependency change.

Frontend Dependencies

- 2 Moderate React Router advisories remain.
- No Critical or High vulnerability remains.
- Automatic remediation requires a breaking major-version upgrade.

Browser Token Persistence

The implemented frontend continues to use the existing browser-side JWT persistence design.

DDP-085 did not redesign the authentication architecture because the issue scope required minimal targeted remediation rather than a new authentication model.

Final SDS Security Documentation

The verified A04 security-design and threat-risk findings are referenced for incorporation into the final SDS under DDP-088.

These residual items do not invalidate the verified DDP-085 Critical/High security release gate.

18. Security Release Gate

The following DDP-085 release-gate conditions have been verified:

- OWASP A01-A10 assessment completed;
- authorization controls verified;
- authentication controls verified;
- account lockout implemented and verified;
- dependency scans completed;
- backend Critical vulnerabilities: **0**;
- backend High vulnerabilities: **0**;
- frontend Critical vulnerabilities: **0**;
- frontend High vulnerabilities: **0**;

- backend regression passed;
- frontend regression passed;
- backend CI passed;
- backend security PR peer-reviewed and merged;
- frontend security PR merged;
- accepted backend revision deployed;
- frontend deployed;
- HTTPS verified;
- CORS verified;
- security headers verified;
- deployed authentication behavior verified;
- runtime security logging verified;
- no authentication passwords or token values exposed in the verified runtime security entries.

Security Verification Gate Result

PASS

19. Evidence References

Backend

- DDP-085 Issue: `darshana-opticals-osms/backend#91`
- Backend Security PR: `darshana-opticals-osms/backend#108`
- Backend PR #108 Merge Commit: `0881662c582c42768c010042a7a3d4be8bfd4d1f`
- Final backend regression: **118 / 118 suites, 2075 / 2075 tests**
- Backend CI: **Run #501 - PASS**
- Latest backend verification**: 118 / 118 suites, 2076 / 2076 tests**
- Latest Backend CI**: Run #517 - PASS**
- Detailed backend assessment: `docs/security/owasp-assessment.md`

Frontend

- Frontend Security PR: `darshana-opticals-osms/frontend#68`
- Frontend PR #68 Merge Commit: `a21e1a0ad420e3ea07be1896a38898d9e496dcf4`
- Final frontend verification: **110 / 110 test files, 1341 / 1341 tests**

Deployment

- Render backend: `https://osms-backend-staging.onrender.com`
- Vercel frontend: `https://darshana-opticals.vercel.app`

Runtime Logging

Verified Render events:

- `[SecurityAuth] LOGIN_FAILED`
- `[SecurityAuth] LOGIN_BLOCKED_LOCKED`
- `[SecurityAccess] AUTHENTICATION_REJECTED`

20. Final Conclusion

The OSMS application has completed the planned DDP-085 OWASP Top 10 security verification.

All ten OWASP categories were assessed against the implemented system using a combination of:

- automated tests;
- integration tests;
- dependency scanning;
- code review;
- CI verification;
- deployment checks;
- controlled authentication testing;
- frontend/backend integration testing;
- runtime security-log inspection.

No unresolved Critical or High dependency vulnerability remains in the verified backend or frontend baseline.

The planned frontend and backend post-deployment security verification is complete.

Residual Moderate dependency risks and the existing frontend token-persistence design are documented rather than falsely represented as fully remediated.

The verified A04 security-design and threat-risk findings are tracked under DDP-088 for incorporation into the final SDS.

Overall DDP-085 Security Verification Result

PASS - OWASP SECURITY VERIFICATION COMPLETE